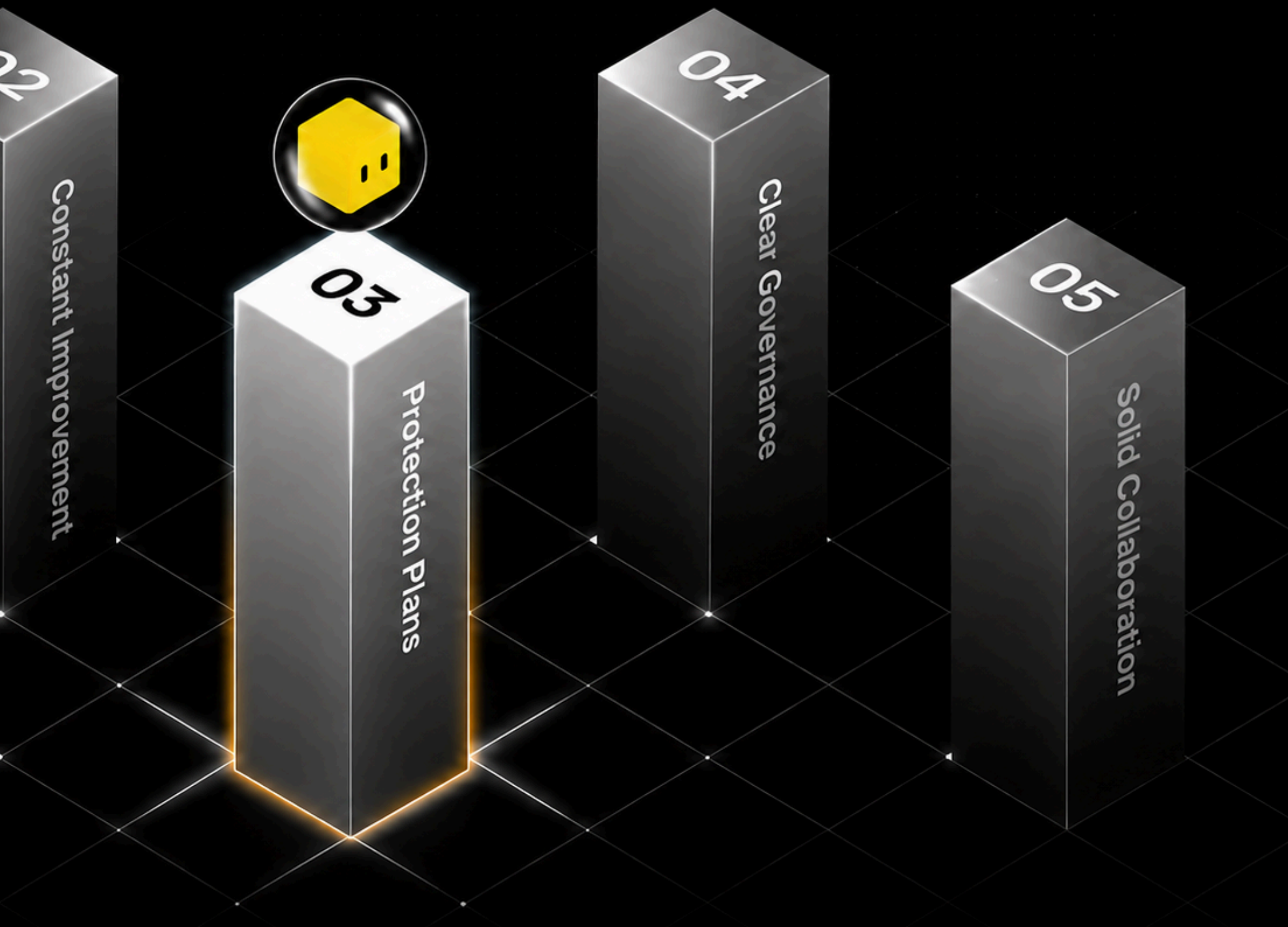


PI-RAG CHECKER



Nguyễn Thanh Tùng
Phan Trần Tường Vy
Trần Đoàn Quang Vũ
Bùi Đức Lân
Nguyễn Minh Hiếu

2A202601871
2A202601701
2A202601999
2A202602037
2A202601685

Bùng nổ AI và khoảng trống bảo mật

Mọi doanh nghiệp đều đang xây dựng AI.

Nhưng rất ít doanh nghiệp biết AI của mình có thực sự an toàn hay không.

78% tổ chức dùng AI trong ít nhất một chức năng;

71% dùng GenAI thường xuyên trong ít nhất một chức năng. [1]



Rủi ro tăng nhANH hơn khả năng kiểm soát



- AI được đưa vào chăm sóc khách hàng, tìm kiếm nội bộ và hỗ trợ quyết định.
- LLM xử lý đồng thời instruction và dữ liệu không tin cậy.
- RAG mở thêm đường vào từ tài liệu, email, ticket, website và knowledge base.
- Một câu trả lời sai có thể trở thành rủi ro vận hành, dữ liệu và uy tín.

PHÂN TÍCH RỦI RO BẢO MẬT



Người dùng



Prompt Injection ⚠



AI Chatbot



Instruction Hijacking ⚠



LLM



RAG Poisoning ⚠



Kho tri thức (RAG)



Data Leakage ⚠



Hệ thống doanh nghiệp



Sai lệch quyết định ⚠



Khoảng trống thị trường và người dùng mục tiêu

Làm thế nào để doanh nghiệp biết AI đã đủ an toàn trước khi đưa vào vận hành?



Doanh nghiệp đã có thể kiểm thử

- ✓ Chức năng
- ✓ Hiệu năng
- ✓ Trải nghiệm người dùng
- ✓ Chất lượng câu trả lời



Nhưng vẫn đang thiếu

- ✗ Prompt Injection
- ✗ RAG Poisoning
- ✗ Evidence tái hiện
- ✗ Readiness Score
- ✗ GO / NO-GO gate



Người dùng đang gặp vấn đề

-  Security Assessor
-  AI Project Owner
-  RAG Engineer
-  QA / DevSecOps

KHÁCH HÀNG MỤC TIÊU



Doanh nghiệp chuẩn bị triển khai AI Chatbot hoặc RAG.

Doanh nghiệp muốn đánh giá mức độ an toàn trước khi đưa AI vào Production.



Đội ngũ AI cần đánh giá trước Production.



Khoảng trống không phải là thiếu AI,
mà là **thiếu một cách chuẩn hóa để đánh giá AI**
trước Production.



PERSONA

NGƯỜI DÙNG TRỰC TIẾP

- Security Assessor
- AI Project Owner
- RAG/Data Engineer
- QA/DevSecOps



STAKEHOLDER

BÊN LIÊN QUAN

- Project Sponsor / Head of AI
- AI/ML Engineer
- Security Team
- Compliance/Risk
- PM và BA



PHÂN KHÚC

KHÁCH HÀNG MỤC TIÊU

- Doanh nghiệp chuẩn bị triển khai chatbot/RAG
- Đội AI cần đánh giá trước Production
- Ngành có dữ liệu nhạy cảm
- Nhà cung cấp giải pháp AI

Bài toán doanh nghiệp: quy trình AS-IS

Mỗi đội tự viết prompt và test case
Chạy thử công trên UI hoặc script riêng
Đánh giá bằng mắt hoặc một LLM judge
Finding thiếu trace và khó tái hiện
Không có regression pack sau khi sửa
Không có release gate thống nhất

NHỮNG CHỨC NĂNG CHÍNH



Assessment Intake

- > Endpoint staging
- > Policy, canary, scope
- > RAG corpus/namespace test



Attack Simulation

- > Direct/Indirect PI
- > Multi-turn
- > RAG Poisoning



Security Evaluation

- > Trace & evidence
- > Severity
- > Readiness Score



Security Report

- > Remediation & owner
- > Regression pack
- > GO / Conditional GO / NO-GO

WORKFLOW CHÍNH: TRƯỚC VÀ SAU KHI CÓ AI



Quy trình Truyền thống

1

Khởi tạo & Chuẩn bị

Khai báo scope. Assessor chọn test case thủ công từ tập mẫu. Tạo poison document bằng tay.

2

Thực thi Test

QA chạy tuần tự các prompt cố định trên hệ thống mục tiêu.

3

Đánh giá Kết quả

Assessor phải đọc và đánh giá ngữ nghĩa từng response hoàn toàn bằng mắt thường.

4

Tổng hợp & Quyết định

Tự phân loại finding, viết báo cáo. Chạy lại (regression) thủ công trước khi ra quyết định Go/No-Go.



Hạn chế Tốn nhiều thời gian tạo biến thể & báo cáo. Kết quả phụ thuộc lớn vào kinh nghiệm chủ quan của người kiểm thử.



Quy trình AI Hỗ trợ

1

Sinh Test (AI-Driven)

AI tự động tạo hàng ngàn biến thể prompt (ngữ cảnh, ngôn ngữ) và tạo tài liệu đầu độc tổng hợp.

2

Thực thi Tự động

Orchestrator điều phối chạy tự động, kiểm soát chặt chẽ giới hạn token và chi phí.

3

Phân tích (AI-Driven)

AI đọc, phân tích ngữ nghĩa, đề xuất điểm rủi ro. Con người chỉ cần can thiệp thẩm định các ca khó (Manual Verify).

4

Báo cáo & Quyết định

AI tự động gom nhóm finding và đề xuất cách khắc phục. Con người kiểm tra lần cuối và chốt Go/No-Go.



Vai trò cốt lõi AI đảm nhiệm phần việc nặng nhọc (tạo test, phân tích lượng lớn). Con người (Rule) kiểm soát chất lượng và chốt quyết định cuối.



PI-RAG CHECKER

**PI-RAG không chỉ tìm lỗi.
PI-RAG giúp doanh nghiệp ra quyết định phát hành AI bằng
bằng chứng.**

THANK YOU